

Dokumentasi Kode Backend Tauco Cap Badak

Phase 1B dan Phase 1C

Clean Architecture

Go + Gin

PostgreSQL

OpenAPI

Local-first

VERSI

1.0

TARGET

Backend Go

TANGGAL

5 Agustus 2026

SCOPE

Phase 1B B1-B4

Atribut	Nilai
Versi dokumen	4.0
Tanggal	5 Agustus 2026
Status kode	Phase 1B B0-B10 dan Phase 1C C0-C10 complete lokal
Runtime	Go, Gin, GORM, PostgreSQL, Redis, Next.js BFF
Mode	Local-first shadow-mode

Backend dan Admin CMS sudah berfungsi lokal, tetapi belum menjadi dependency website production. Production tetap memakai konten file dan Netlify Forms sampai deployment serta cutover Phase 1D disetujui.

1. Topologi Runtime

```
Browser admin
- > Next.js /admin
- > same-origin /admin-api BFF
- > Go REST API /api/v1/admin
- > application service
- > PostgreSQL + Redis + local media storage

Browser publik production
- > Next.js prerender
- > LocalContentSource
- > Netlify CDN dan Netlify Forms

Worker lokal
- > claim durable job PostgreSQL
- > bounded goroutine pool
- > media variant, email, activity, atau cache invalidation
- > success, retry, atau dead-letter
```

Process backend:

Command	Fungsi
cmd/api	Public dan admin REST API
cmd/worker	Durable background worker serta retention loop
cmd/admin	Bootstrap dan recovery akun secara operator-controlled
cmd/migrate	Versioned SQL migration
cmd/seed	Import idempotent konten Phase 1A
cmd/media-import	Ingest media internal melalui CLI

Command	Fungsi
cmd/ops	Replay dead job dan targeted cache purge
cmd/loadcheck	Baseline cold/warm API lokal

2. Struktur Folder dan Fungsi

```
backend/  
|-- cmd/  
|   |-- api/  
|   |-- worker/  
|   |-- admin/  
|   |-- migrate/  
|   |-- seed/  
|   |-- media-import/  
|   |-- ops/  
|   `-- loadcheck/  
|-- internal/  
|   |-- composition/  
|   |-- delivery/api/  
|   |-- auth/  
|   |-- content/  
|   |-- catalog/  
|   |-- media/  
|   |-- contact/  
|   |-- audit/  
|   |-- jobs/  
|   `-- platform/  
|-- migrations/  
|-- openapi/  
|-- docs/  
|-- compose.yaml  
`-- Dockerfile  
  
src/  
|-- app/admin/  
|-- app/admin-api/[...path]/  
`-- features/admin/
```

File pusat

File	Fungsi
backend/cmd/api/main.go	Membaca environment, membangun app, menangani signal.
backend/internal/composition/app.go	Memilih adapter konkret dan mendaftarkan route.
backend/internal/composition/operations.go	Readiness, publishing handler, dan metrics snapshot.
backend/internal/delivery/api/api.gen.go	Type/interface hasil OpenAPI; jangan diedit manual.

File	Fungsi
<code>backend/internal/delivery/api/admin_auth.go</code>	Auth cookie, TOTP, refresh, logout, current user.
<code>backend/internal/delivery/api/admin_content.go</code>	Page draft, history, preview, publish, unpublish.
<code>backend/internal/delivery/api/admin_products.go</code>	Product CRUD, revision, publish, archive.
<code>backend/internal/delivery/api/admin_media.go</code>	Upload, status, retry, dan ready variant response.
<code>backend/internal/delivery/api/admin_inbox_activity.go</code>	Inbox dan activity API.
<code>backend/internal/auth/application/service.go</code>	Auth/session/TOTP orchestration dan authorization.
<code>backend/internal/content/application/admin.go</code>	Immutable page revision workflow.
<code>backend/internal/catalog/application/admin.go</code>	Stable-slug product workflow.
<code>backend/internal/jobs/application/worker.go</code>	Claim, heartbeat, bounded concurrency, retry/dead.
<code>src/app/admin-api/[...path]/route.ts</code>	BFF path/method allowlist dan cookie transport.
<code>src/features/admin/admin-api.ts</code>	Typed browser-side CMS request helper.

3. Batas Clean Architecture

Layer	Tanggung jawab
Domain	Entity, value, invariant, canonical representation
Application	Use case, authorization, transaction orchestration, port
Delivery	HTTP parsing, OpenAPI DTO, cookie/header, problem response
Repository	PostgreSQL dan Redis adapter
Platform	Database, cache, storage, email, logging, limiter, metrics
Composition	Concrete dependency injection dan process lifecycle

Domain dan application tidak mengimpor Gin, GORM, Redis, atau Next.js. Handler tidak menjalankan query GORM langsung. Architecture test menjaga arah dependency.

4. Flow Aplikasi

4.1 Public read lokal

```
GET /api/v1/{home|about|tauco-guide|products}
  -> request ID, trace, security header, CORS, rate limit
  -> generated OpenAPI handler
  -> published-only reader
  -> Redis cache-aside
      hit                -> validasi domain -> response
      miss/error/corrupt -> PostgreSQL -> isi/perbaiki cache
  -> strong ETag -> 200 atau conditional 304
```

PostgreSQL tetap source of truth. Product yang tidak published, archived, atau tidak dikenal menghasilkan RFC 7807 404.

4.2 Login dan TOTP admin

```
POST /admin-api/auth/login
  -> Next.js BFF allowlist
  -> Go login rate limit dan generic auth error
  -> Argon2id password verification
  -> bila TOTP aktif: validasi TOTP atau recovery code sekali pakai
  -> session PostgreSQL + refresh token hash
  -> RS256 access JWT + opaque refresh + CSRF cookie
  -> browser hanya menerima cookie, bukan token JSON
```

Access token berumur pendek. Refresh dirotasi setiap penggunaan. Reuse token lama mencabut session. TOTP secret disimpan terenkripsi AES-256-GCM. Mutation admin mewajibkan session MFA, permission, Origin/Fetch Metadata, dan CSRF.

4.3 Page editor Home dan About

```
GET page -> latest revision + ETag
Save Draft
  -> If-Match latest ETag
  -> validasi schema terstruktur + fact-check
  -> INSERT immutable revision baru
  -> append activity log
Preview -> render revision spesifik, noindex/no-store
Publish
  -> cek revision dan semua media ready
  -> INSERT immutable published revision
  -> pindahkan published pointer dalam transaksi
  -> enqueue content.invalidate_cache
Unpublish -> kosongkan pointer + enqueue invalidation
```

Dua Save Draft concurrent terhadap ETag yang sama menghasilkan satu success dan satu 409/412 ; revision lama tidak di-update atau dihapus.

4.4 Product CMS

```
Create product -> stable slug + empty draft
Edit metadata/content -> immutable revision + ETag
Preview -> revision spesifik
Publish/unpublish -> published pointer + cache job + audit
Archive -> public reader mengecualikan product
Unarchive -> product kembali editable, tidak otomatis published
```

Slug tidak boleh diubah setelah produk pernah dipublish. Field harga, SKU, sertifikasi, dan claim yang belum diverifikasi tetap dapat dihilangkan.

4.5 Media CMS

```
multipart upload maksimal 10 MiB
-> content-type, magic byte, decode, pixel/dimension validation
-> normalize dan re-encode original privat tanpa EXIF/GPS
-> media_assets + media.generate_variants job
worker
-> WebP 320/640/1280 tanpa upscale, maksimum 2 goroutine resize
-> seluruh variant sukses: ready
-> transient failure: retry; terminal: failed/dead
```

Public route hanya menyajikan ready display/variant, bukan original. Editor menolak publish jika revision menunjuk media yang belum ready.

4.6 Contact, inbox, dan activity

```
POST public contact
-> strict validation + consent + honeypot + Idempotency-Key
-> satu transaksi: contact_messages + email job + activity job
-> 201 tanpa menunggu SMTP

Admin inbox
-> cursor/filter/list/detail
-> GET tidak mengubah status
-> explicit status mutation memakai If-Match
-> append activity event dengan metadata allowlist tanpa PII
```

Retention pesan adalah 12 bulan. Worker melakukan purge bounded saat startup dan setiap 24 jam.

4.7 Publishing worker dan cache

```
content.invalidate_cache job
-> payload tag allowlist: home, about, products, product:{slug}
-> atomic Redis generation increment
-> repeat delivery aman karena generation hanya bergerak maju
-> success | retry dengan backoff | dead-letter
```

Tidak ada wildcard Redis delete atau full database purge. Phase 1D akan menambahkan remote Next.js revalidation setelah runtime deployment dipilih.

4.8 Production saat ini

```
content/*.json -> LocalContentSource + Zod -> Next.js initial HTML -> Netlify
contact form -> Netlify Forms -> inbox dan email notification
```

Admin dan Go API tetap lokal. Karena itu C10 tidak mengubah canonical, sitemap, ranking, form submission production, atau public content.

5. Route API

Public:

```
GET /api/v1/home
GET /api/v1/about
GET /api/v1/tauco-guide
GET /api/v1/products
GET /api/v1/products/{slug}
POST /api/v1/contact-messages
```

Admin route groups:

```
/api/v1/admin/auth/*
/api/v1/admin/pages/{key}/*
/api/v1/admin/products/*
/api/v1/admin/media/*
/api/v1/admin/contact-messages/*
/api/v1/admin/activity-logs
```

Media dan operations:

```
GET /api/v1/media/{id}/display.webp
GET /api/v1/media/{id}/variants/{width}.webp
GET /health/live
GET /health/ready
GET /internal/metrics
```

Kontrak lengkap ada di `backend/openapi/openapi.yaml` . Error memakai RFC 7807 `application/problem+json` dan selalu memiliki `requestId` .

6. Database

Schema aplikasi: `tauco_app` . Migration final lokal:

```
version=6 dirty=false
```

Kelompok	Tabel
Content	<code>pages</code> , <code>page_revisions</code> , <code>page_revision_media</code>
Catalog	<code>products</code> , <code>product_revisions</code> , <code>product_revision_media</code>
Media	<code>media_assets</code> , <code>media_variants</code>
Contact/worker	<code>contact_messages</code> , <code>background_jobs</code> , <code>activity_logs</code>
Auth/RBAC	<code>admin_users</code> , <code>roles</code> , <code>permissions</code> , <code>user_roles</code> , <code>role_permissions</code>
Session/MFA	<code>admin_sessions</code> , <code>admin_refresh_tokens</code> , <code>mfa_credentials</code> , <code>mfa_recovery_codes</code>

Role database dipisah:

- `tauco_migrator` memiliki DDL dan migration metadata;
- `tauco_runtime` melayani public API dan worker dengan privilege terbatas;
- `tauco_admin` dipakai CMS dan admin CLI untuk operasi yang diaudit.

Schema hanya berubah melalui SQL migration. `AutoMigrate` dan UUID yang dibuat database dilarang. ID aplikasi memakai UUIDv7.

7. Security dan Privacy

Kontrol	Implementasi
Password	Argon2id, minimum policy, generic invalid credential
MFA	TOTP wajib, replay protection, recovery code sekali pakai
JWT	RS256, typ/kid/issuer/audience/expiry/session validation
Refresh	opaque random token, hash at rest, rotation dan reuse detection
Cookie	HttpOnly access/refresh, SameSite, Secure pada remote, no-store

Kontrol	Implementasi
CSRF	double-submit token, Origin/Referer, Fetch Metadata
Authorization	permission per operation, default deny
Rate limit	Redis Lua atomic; local bounded fallback
Upload	size, magic byte, decode, dimension, animation, metadata stripping
Log/metrics	tidak menyimpan body, credential, raw IP, email, telepon, token
Admin indexing	route dan response memakai noindex/no-store

Next.js BFF hanya meneruskan kombinasi path dan method yang diizinkan. Origin Go tidak pernah dikirim ke client bundle. Tidak ada public registration atau Supabase Auth pada Phase 1C.

8. Menjalankan Lokal

Siapkan dependency:

```
npm.cmd ci
npm.cmd run backend:compose:up
npm.cmd run backend:migrate:up
npm.cmd run backend:seed:phase1a
```

Bootstrap admin satu kali:

```
npm.cmd run backend:admin -- bootstrap email@example.com
```

Jalankan empat terminal:

```
npm.cmd run backend:dev
npm.cmd run backend:worker
npm.cmd run dev
```

Buka `http://localhost:3000/admin/login`. Password dimasukkan melalui prompt tersembunyi. Hubungkan TOTP setelah login pertama.

Environment lokal utama:

Variable	Fungsi
<code>DATABASE_URL</code>	PostgreSQL runtime
<code>ADMIN_DATABASE_URL</code>	CMS dan admin CLI
<code>MIGRATION_DATABASE_URL</code>	Migration/seed

Variable	Fungsi
REDIS_URL	Cache dan rate limit
ADMIN_CMS_ENABLED	Mengaktifkan route admin Next.js lokal
ADMIN_API_ORIGIN	Origin Go server-only untuk BFF
CURSOR_HMAC_SECRET	Signed cursor
CONTACT_HMAC_SECRET	Contact idempotency digest
RATE_LIMIT_HMAC_SECRET	Privacy-safe limiter key
METRICS_BEARER_TOKEN	Protected metrics
SMTP_*	Notification adapter
MEDIA_LOCAL_ROOT	Private local object root

File `.env.local` dan `backend/.env` tidak masuk Git.

9. Operations dan Recovery

- Readiness worker: `npm.cmd run backend:worker:ready`.
- Reset password: `npm.cmd run backend:admin -- reset-password <email>`.
- Reset TOTP: `npm.cmd run backend:admin -- reset-totp <email>`.
- Revoke session: `npm.cmd run backend:admin -- revoke-sessions <email>`.
- Replay dead job: `npm.cmd run backend:ops -- job-replay <id> <reason>`.
- Cache recovery: `npm.cmd run backend:ops -- cache-purge <tag...>`.
- Metrics: `GET /internal/metrics` dengan bearer token lokal.

Detail decision tree tersedia di `PHASE_1C_RUNBOOK.md`. Jangan mengubah row job, revision, session, atau cache generation secara manual.

10. Quality Gate

```
npm.cmd run backend:format:check
npm.cmd run backend:generate:check
npm.cmd run backend:test:integration
npm.cmd run backend:race
npm.cmd run backend:vet
npm.cmd run backend:lint
npm.cmd run backend:vuln
npm.cmd run backend:load
npm.cmd run backend:container:build
npm.cmd run check:frontend
npm.cmd run test:admin
npm.cmd run test:e2e
npm.cmd run qa:g6
```

Windows Application Control dapat memblokir executable test Go temporer. Runner akan memakai Docker Linux untuk package terdampak. Evidence final ada di `PHASE_1C_QUALITY_REPORT.md`.

11. Boundary Phase 1D

Phase 1C tidak melakukan:

- deployment API, worker, PostgreSQL, Redis, atau storage;
- public content source cutover;
- Netlify Forms to Go contact cutover;
- remote Next.js revalidation;
- backup/restore drill dan production secret rotation;
- custom domain atau production CMS enablement.

Semua perubahan cloud, push, merge, deploy, dan cutover memerlukan instruksi owner serta checklist Phase 1D terpisah.